🏦Official Banking-Grade Engineering Checklist

Purpose: This checklist is designed as a **formal reference** when presenting MNbarh (or any financial system) to **banks, payment processors, regulators, or auditors**.
Passing this checklist means the system is **bank-grade**, not MVP-grade.

Ledger & Accounting (NON-NEGOTIABLE)

Ledger Design

- [ ] **Append-only ledger** (no UPDATE / DELETE ever)
- [ ] Balance is **derived**, not stored
- [ ] Every ledger entry has:
- immutable ID
- timestamp
- reason code (TOPUP, HOLD, RELEASE, REFUND, FEE)
- actor (system / admin / gateway)
- [ ] Database-level protection (triggers / constraints) preventing mutation

Auditability

- [ ] Full transaction history reconstructable from ledger alone
- [ ] No hidden balances or shadow fields

✅**Bank Expectation**: If balance ≠ sum(ledger), system is rejected.

Wallet Architecture

- [ ] Wallet is **container only** (no money logic in UI)
- [ ] Wallet status enforced (ACTIVE / FROZEN / CLOSED)
- [ ] Debit cannot exceed derived balance
- [ ] All transfers are **atomic** (debit + credit in one transaction)
- [ ] Idempotency enforced for every financial operation

✅**Bank Expectation**: Double-charge must be mathematically impossible.

Escrow & Ownership Model

- [ ] Escrow HOLD clearly separates **ownership vs availability**
- [ ] Escrow RELEASE is explicit, logged, and authorized
- [ ] Escrow never auto-releases from payment confirmation
- [ ] Escrow logic is **internal truth**

❌Forbidden: - Auto-release on webhook - UI-triggered release

✅**Bank Expectation**: Money ≠ Ownership

Payment Gateway Integration

- [ ] Gateway is treated as **external signal**, not source of truth
- [ ] Webhooks are:
- signature-verified
- raw-body validated
- idempotent
- [ ] Gateway events only create **ledger credits**
- [ ] No business decisions in webhook handlers

❌Forbidden: - Trusting redirect URLs - Trusting frontend callbacks

✅**Bank Expectation**: Webhook ≠ command

Reconciliation (CRITICAL)

- [ ] Reconciliation is **read-only**
- [ ] Detects mismatches, never fixes them
- [ ] No ledger writes during reconciliation
- [ ] No escrow release during reconciliation
- [ ] All discrepancies classified and logged

Mismatch types: - MISSING_PAYMENT - AMOUNT_MISMATCH - DELAYED_PAYMENT - DUPLICATE_PAYMENT - GATEWAY_FAILURE

✅**Bank Expectation**: Humans approve fixes — systems only report.

Security & Trust Model

- [ ] Frontend is **never trusted**
- [ ] All money movement is backend-only
- [ ] Role-based access (Admin ≠ Operator ≠ System)
- [ ] Dual approval for sensitive actions
- [ ] Rate limiting on financial endpoints

✅**Bank Expectation**: Assume breach — system must survive it.

Audit & Compliance

- [ ] Immutable command log for:
- escrow release
- refunds
- overrides
- [ ] Actor + timestamp on every decision
- [ ] Manual actions require justification text
- [ ] Historical state reconstruction possible

Standards aligned with: - PCI-DSS (logic separation) - SOX-style auditability - ISO-27001 principles

---

Testing (BANK-GRADE REQUIREMENT)

Mandatory Safety Tests

- [ ] No ledger mutation tests
- [ ] Overdraft prevention tests
- [ ] Concurrent debit protection
- [ ] Idempotency tests
- [ ] Reconciliation safety tests

❌If any test fails → **NO DEPLOY**

✅**Bank Expectation**: Tests are part of compliance, not QA.

Explicit Questions Banks Will Ask

Question	Expected Answer
Can balance be edited?	❌NO
Can UI move money?	❌NO
Can money disappear?	❌NO
Is every action auditable?	✅YES
Can escrow auto-release?	❌NO
Are webhooks authoritative?	✅YES (for arrival only)

🛩️FINAL VERDICT CRITERIA

If **ALL** sections pass:

✅System qualifies as **Bank-Grade Financial Infrastructure**
❌Missing even one → **Rejected by bank / processor**

This document can be safely used as:

- Bank technical due-diligence reference
- Payment processor onboarding checklist
- Internal compliance gate
- Investor / audit explanation

Status:✔️ Proven by MNbarh Phase 4.1 → 4.4 implementation